

AI Governance — Foundations

The shelf, the playbook, the toolbox

- Binding law (the floor) ■ Voluntary guidance ■ Frameworks & standards
- Controls (the toolbox) ■ Traps / red lines ■ Definitions

The colours never change. Blue is always binding law, orange is always a control, and so on — so your eye files each idea by its colour.

1 • The AU rulebooks — the shelf

Australia has no single "AI law." Governance pulls from a small shelf of documents — and they come in **two tiers**. Knowing which tier something sits in tells you whether it can *punish* you, or just *guide* you.

TIER 1 Binding law — has teeth

Break these and the firm can be **punished or sued**. This is the floor you cannot go below.

- **Privacy Act 1988** (+ the APPs) — the rules for handling people's personal data. *The big one for a financial firm.*
- **Anti-discrimination Acts** (e.g. Racial Discrimination Act 1975) — you can't produce discriminatory outcomes. Bites *if* AI makes decisions about people.

TIER 2 Voluntary guidance — best practice

No direct penalty — but the **expected standard**, and quietly becoming what everyone's held to.

- **AI Ethics Principles** (8 values) = "*what we believe*"
- **Voluntary AI Safety Standard** (10 guardrails) = "*what we're doing*"

⚠️ Trap

It's the Privacy Act **1988** — not 1998. Citing the wrong year of an Act quietly kills your credibility in a governance document.

2 · The Voluntary AI Safety Standard — the playbook

Tier 2 had two documents. The Ethics Principles are the *values*. This one is the **instruction manual** — the government's practical "here's what to actually DO" list. It's **10 guardrails**, and they're the backbone of any AI policy.

10 guardrails



written as house rules



= your AI Use Policy

Who's responsible

- **1 · Accountability** — name who owns AI governance + how it's run
- **9 · Records** — keep documentation so others can check you complied

Managing the risk

- **2 · Risk management** — a process to find + reduce AI risks (*your assessment skill*)
- **3 · Data governance** — protect data, manage its quality + where it came from
- **4 · Testing** — test AI before *and* during use; monitor it

Protecting people

- **5 · Human oversight** — a human can step in / override across the AI's life
- **6 · Transparency** — tell people when AI is making or affecting a decision
- **7 · Contestability** — give affected people a way to challenge an outcome

Working with others

- **8 · Supply-chain transparency** — be open with partners about your AI so they can manage risk
- **10 · Stakeholder engagement** — consult the people affected (safety, fairness, inclusion)

💡 **The key insight:** your AI policy isn't invented from scratch — it's these **10 guardrails turned into rules for your firm**. Accountability → your Roles section. Risk management → your Approval section. Oversight + transparency + contestability → your Acceptable/Prohibited-use rules.

3 · The controls toolbox — the kit

The secret that makes governance people fast: when they find a risk, they don't invent a fix — they **pick from a standard kit** of controls. Sorted the way you already know: **Data · Model · Human-process**.

Data controls — control what goes in / is kept

- **Data minimisation** — collect only what's needed
- **Retention limits** — delete it when the job's done
- **Approved-tools-only** — sensitive data ONLY into secured/approved AI, never public
- **Access controls** — only authorised people can see it
- **Redaction** — strip identifying details before the AI sees them

Model / technical controls — change the AI itself

- **Bias / fairness testing** — check outcomes aren't skewed, before AND during use
- **Accuracy testing** — make sure it's reliable before trusting it
- **Logging / audit trail** — record what the AI did, so you can review it
- **No hard auto-decisions** — don't let it auto-reject on a brittle rule

Human / process controls — people + procedure around it

- **Human-in-the-loop** — a person reviews/approves before it acts
- **Approval gate** — new AI tool must be assessed before adoption
- **Right to explanation** — tell affected people WHY
- **Right to appeal** — let them challenge the outcome
- **Named accountable owner** — someone senior on the hook
- **Vendor due diligence** — check the AI supplier's data protections
- **Staff training** — people actually know the rules
- **Incident response** — a plan for when it goes wrong
- **Review cadence** — regular audits (e.g. quarterly)

💡 **Writing the policy = toolbox-picking.** For each situation, reach in and grab the right control(s). Example: "staff want AI, but we hold sensitive client data" → **Approved-tools-only + Access controls + Redaction.**

How the three fit together

The whole foundation in one line

The shelf tells you which rules apply → **the playbook** (10 guardrails) tells you what to do → **the toolbox** gives you the fixes. Your **AI Use Policy** simply writes all three down as rules for one firm.